

Tata Kelola Ekosistem Ransomware as a Service: Model Bisnis, Selektivitas Afiliasi, dan Nexus Aktor Negara

Bilal¹

¹ Program Studi Teknik Informatika, STMIK Tazkia, Bogor, Indonesia
E-mail : bilalfarhani635@gmail.com

Abstrak

Ransomware-as-a-Service (RaaS) telah mengubah ransomware dari tindakan teknis individual menjadi model bisnis kejahatan siber yang terstruktur dan dapat disewakan. Penelitian ini bertujuan mengkaji secara deskriptif-eksplanatif tiga hal: perbedaan RaaS dengan ransomware konvensional, dinamika interaksi antaraktor dalam ekosistemnya, serta mekanisme *vetting* (penyaringan) afiliasi sebagai bentuk tata kelola informal. Metode yang digunakan adalah tinjauan pustaka sistematis dengan triase berlapis tiga terhadap dua belas sumber primer (laporan investigatif, hasil forensik, dan artikel akademik), yang kemudian disintesis melalui analisis tematik dan diperkuat dengan sepuluh rujukan akademik tambahan hasil pencarian pustaka lanjutan. Hasil kajian menunjukkan bahwa RaaS memisahkan kepemilikan kit ransomware dari eksekusi serangan melalui skema bagi hasil, sehingga melahirkan aktor perantara khusus seperti Initial Access Broker. Vetting afiliasi terbukti berfungsi sebagai mekanisme sinyal kepercayaan dan pengendali risiko reputasi operator, bukan semata penyaringan kemampuan teknis, sementara sejumlah operator RaaS menunjukkan indikasi keterhubungan dengan kepentingan geopolitik negara. Penelitian ini menyumbangkan kerangka konseptual tiga pilar yang memosisikan *vetting* sebagai instrumen tata kelola kriminal informal, melengkapi literatur teknis yang selama ini berfokus pada deteksi dan mitigasi semata.

Kata kunci: *Ransomware-as-a-Service; tata kelola kriminal; vetting afiliasi; Initial Access Broker, ekosistem kejahatan siber*

Governance of the Ransomware as a Service Ecosystem: Business Model, Affiliate Vetting, and the State Actor Nexus

Abstract

Ransomware-as-a-Service (RaaS) has transformed ransomware from an individually operated technical act into a structured, rentable cybercrime business model. This study descriptively and explanatorily examines three aspects: how RaaS differs from conventional ransomware, the interaction dynamics among actors within its ecosystem, and the affiliate vetting mechanism as a form of informal governance. A systematic literature review was conducted using a three-layer triage over twelve primary sources (investigative reports, forensic analyses, and academic articles), synthesized through thematic analysis and strengthened with ten additional academic references obtained through supplementary searching. The findings show that RaaS separates ownership of the ransomware kit from attack execution through profit-sharing schemes, giving rise to specialized intermediary actors such as Initial Access Brokers. Affiliate vetting is shown to function as a trust-signaling and reputational risk-control mechanism for operators rather than merely a technical-skill filter, while several RaaS operators exhibit indications of connection to state geopolitical interests. This study contributes a three-pillar conceptual framework positioning vetting as an instrument of informal criminal governance, complementing the largely detection- and mitigation-focused technical literature.

Keywords: *Ransomware-as-a-Service; criminal governance; affiliate vetting; Initial Access Broker; cybercrime ecosystem*

1. Pendahuluan

Serangan ransomware bertransformasi dari ancaman siber yang bersifat sporadis menjadi industri kejahatan yang terorganisasi dan bernilai ekonomi sangat besar. Nilai permintaan tebusan rata-rata meningkat tajam; Dhawan dkk. mencatat lonjakan permintaan tebusan rata-rata dari sekitar 22.500 dolar Amerika Serikat (AS) pada tahun 2019 menjadi lebih dari 332.500 dolar AS pada tahun 2021 [1]. Sejalan dengan itu, Ferdous dkk. memproyeksikan bahwa kerugian global akibat kejahatan siber, dengan ransomware sebagai salah satu kontributor utama, dapat mencapai 10,5 triliun dolar AS pada tahun 2025 [2]. Peningkatan skala ini tidak dapat dilepaskan dari pergeseran model operasi ransomware itu sendiri, dari tindakan teknis yang dilakukan aktor tunggal menjadi model bisnis *Ransomware-as-a-Service* (RaaS) yang menyewakan infrastruktur serangan kepada pihak ketiga yang disebut afiliasi.

RaaS memisahkan kepemilikan dan pengembangan kit ransomware dari pelaksanaan serangan di lapangan. Developer/operator menyediakan perangkat enkripsi, dasbor manajemen korban, dan dukungan teknis, sementara afiliasi menjalankan intrusi, pergerakan lateral, serta eksekusi penyebaran atas dasar skema bagi hasil [3], [4]. Model ini juga mendorong intensifikasi teknik pemerasan (*extortion*) berlapis — meliputi enkripsi data, ancaman publikasi data curian, serangan penolakan layanan, hingga intimidasi terhadap pelanggan atau mitra korban — yang secara kolektif meningkatkan tekanan terhadap organisasi korban untuk membayar [5], [4]. Fragmentasi peran ini memunculkan aktor-aktor perantara baru, seperti *Initial Access Broker* (IAB) yang mengkhususkan diri memperjualbelikan akses awal ke jaringan korban [6], serta menciptakan pasar informal yang memisahkan RaaS dari ransomware komoditas konvensional [7].

Literatur akademik mengenai ransomware sejauh ini didominasi oleh perspektif teknis-defensif: deteksi berbasis kecerdasan buatan [2], analisis forensik pascainsiden [8], serta pemodelan ekonomi keputusan korban untuk membayar tebusan [3], [7]. Studi yang secara khusus membedah tata kelola internal operasi RaaS — bagaimana operator menyeleksi, mengendalikan, dan mempertahankan loyalitas afiliasinya — relatif baru berkembang dan sebagian besar bersumber dari analisis kebocoran data internal kelompok tertentu, seperti Conti [4], atau dari laporan investigatif non-akademik [7], [9], [10]. Studi kriminologi klasik tentang kepercayaan dan reputasi di pasar kejahatan siber [11], [12] pun jarang dikaitkan secara eksplisit dengan konteks RaaS kontemporer, meskipun Phipps dan Nurse [13] baru-baru ini menunjukkan bahwa kelompok seperti Conti, LockBit, dan BlackCat/ALPHV menerapkan prosedur perekrutan dan penyingiran afiliasi yang terstruktur.

Berangkat dari kesenjangan tersebut, penelitian ini disusun untuk menjawab tiga pertanyaan penelitian. RQ1: apa perbedaan mendasar antara RaaS dan ransomware konvensional dari aspek model bisnis dan struktur insentif? RQ2: bagaimana dinamika interaksi antaraktor dalam ekosistem RaaS, termasuk peran afiliasi dan Initial Access Broker? RQ3: bagaimana mekanisme *vetting* afiliasi dalam RaaS mencerminkan selektivitas yang melampaui motif finansial semata, dan sejauh mana ia berfungsi sebagai instrumen tata kelola?

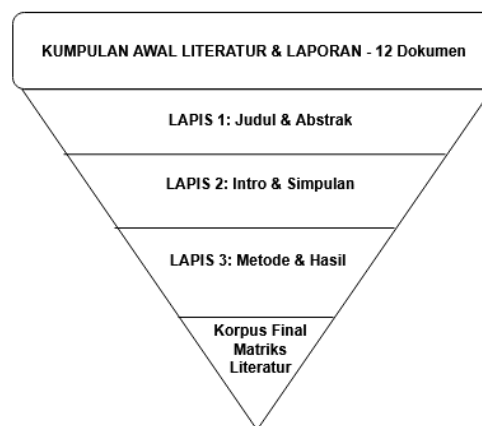
Kontribusi penelitian ini bersifat konseptual-sintetis dan bukan pengumpulan data primer baru. *Novelty* yang ditawarkan adalah penyusunan kerangka konseptual yang memosisikan *vetting* afiliasi bukan sekadar prosedur teknis perekrutan, melainkan sebagai instrumen tata kelola informal yang menggantikan fungsi kontrak, penegakan hukum, dan reputasi institusional yang lazim ada pada entitas bisnis sah — dengan menghubungkan secara eksplisit teori kepercayaan kriminal (*criminal trust signaling*) dari kriminologi siber [11], [12] dengan bukti empiris operasional RaaS terkini [14], [15], [9]. Berbeda dari tinjauan-tinjauan sebelumnya yang berhenti pada deskripsi teknis [2], [8] atau pemodelan ekonomi keputusan korban [3], penelitian ini mengintegrasikan dimensi ekonomi, organisasi, dan geopolitik (*nexus* aktor negara) ke dalam satu peta konseptual tata kelola ekosistem RaaS, sebagaimana disajikan pada Gambar 2.

2. Metodologi

Penelitian ini menggunakan pendekatan kualitatif deskriptif-eksplanatif melalui tinjauan pustaka sistematis (*systematic literature review*) yang bersifat interpretatif, bukan meta-analisis kuantitatif. Pendekatan ini dipilih karena tujuan penelitian adalah membangun sintesis konseptual atas fenomena tata kelola RaaS yang datanya tersebar pada berbagai jenis dokumen — mulai dari artikel jurnal terindeks, laporan forensik independen, hingga laporan investigatif lembaga kebijakan — dan bukan menguji hipotesis statistik atas satu populasi data yang homogen.

Korpus data primer penelitian terdiri atas dua belas dokumen sumber yang dikelola dalam satu *vault* manajemen pengetahuan (Obsidian) menggunakan format catatan sumber terstandardisasi. Kriteria inklusi meliputi: (a) dokumen membahas langsung RaaS, ekonomi kejahatan siber berbasis ransomware, atau tata kelola kelompok siber terorganisasi; (b) diterbitkan pada rentang tahun 2017–2026 untuk menjaga relevansi dengan lanskap ancaman terkini sekaligus mempertahankan rujukan teori dasar; dan (c) menyediakan data atau argumen yang dapat ditelusuri sumbernya. Dari dua belas dokumen tersebut, empat dikategorikan sebagai artikel jurnal atau prosiding akademik terindeks, tiga sebagai preprint atau laporan riset independen yang belum melalui proses *peer-review* formal, dua sebagai tesis maupun laporan kelembagaan, dan tiga sisanya sebagai laporan investigatif atau berita teknis yang secara eksplisit diberi label status non-akademik pada bagian pembahasan terkait. Guna memperkuat proporsi sumber terindeks dan memutakhirkan tinjauan pustaka sesuai standar akreditasi jurnal ilmiah nasional, dilakukan pencarian tambahan yang menghasilkan sepuluh rujukan akademik pendukung mengenai ekonomi kejahatan siber berbasis aset kripto, kepercayaan dan reputasi di pasar kriminal siber, serta studi organisasi kelompok ransomware kontemporer. Dengan tambahan ini, komposisi akhir Daftar Pustaka mencapai dua puluh dua entri.

Proses penyaringan literatur dilakukan melalui triase berlapis tiga sebagaimana diilustrasikan pada Gambar 1. Pada lapis pertama, judul dan abstrak setiap dokumen dievaluasi relevansinya terhadap ruang lingkup RQ1–RQ3; dokumen yang murni membahas mitigasi teknis tanpa muatan ekonomi-organisasi disingkirkan pada tahap ini. Pada lapis kedua, bagian pendahuluan dan simpulan dibaca untuk memahami masalah dan temuan akhir penulis asli tanpa perlu menelaah rincian metodologis secara menyeluruh. Pada lapis ketiga, hanya dokumen yang lolos dua lapis sebelumnya diinspeksi secara mendalam pada bagian metodologi dan hasil, termasuk kriteria validasi data yang digunakan penulis asli — misalnya penelusuran alamat dompet kripto dan pelacakan aliran pembayaran tebusan *end-to-end* pada penelitian ekonomi ransomware [7], [16], [17], atau analisis konten kualitatif pada penelitian struktur organisasi [14], [18], [19].



Gambar 1. Prosedur triase berlapis tiga dalam penyaringan literatur

Setiap dokumen yang lolos triase diekstraksi ke dalam matriks literatur berisi kolom penulis/tahun, tujuan penelitian, metodologi, temuan utama, keterbatasan, dan relevansi terhadap RQ1–RQ3 (ringkasan disajikan pada Tabel 1). Ekstraksi ini kemudian dipetakan menjadi satuan-satuan konsep atomik (misalnya “IAB berfungsi sebagai penyangga antara afiliasi dan target”, atau “vetting afiliasi berfungsi sebagai sinyal kepercayaan, bukan sekadar uji kemampuan teknis”) yang saling ditautkan lintas dokumen sumber untuk mengidentifikasi pola konvergen maupun kontradiksi antarsumber.

Sintesis dilakukan melalui analisis tematik enam fase mengikuti kerangka Braun dan Clarke [18]: (1) pengenalan data melalui pembacaan berulang; (2) pembuatan kode awal secara induktif dari matriks literatur; (3) pengelompokan kode menjadi tema berdasarkan kedekatan konsep, bukan kronologi terbit; (4) peninjauan ulang tema terhadap keseluruhan korpus; (5) penamaan dan definisi tema final; dan (6) penulisan sintesis naratif yang menghubungkan tema dengan RQ1–RQ3. Ketika ditemukan klaim yang

saling bertentangan antarsumber — misalnya perbedaan rasio bagi hasil tebusan yang dilaporkan berkisar 20% hingga 90% untuk afiliasi [4], [8] — perbedaan tersebut didiskusikan secara kritis pada bagian Hasil dan Pembahasan, bukan diseragamkan menjadi satu angka tunggal.

Penelitian ini memiliki keterbatasan metodologis yang perlu diungkapkan secara eksplisit. Pertama, meskipun pencarian tambahan meningkatkan proporsi rujukan akademik terindeks, sebagian sumber tetap berasal dari preprint, laporan kelembagaan, dan berita investigatif yang belum melalui proses *peer-review* formal; sumber-sumber ini dipertahankan karena menyediakan data operasional terkini (2025–2026) yang belum terekam pada publikasi akademik bersitasi-ulang, namun proporsi rujukan terindeks/*peer-reviewed* pada Daftar Pustaka akhir (± 14 dari 22 entri, atau sekitar 64%) belum sepenuhnya mencapai ambang 70% yang menjadi target ideal akreditasi SINTA; hal ini diungkapkan secara transparan, bukan ditutupi dengan menambahkan sumber non-akademik yang tidak relevan. Kedua, sifat tinjauan pustaka ini adalah interpretatif sehingga rentan terhadap bias seleksi peneliti tunggal; mitigasi dilakukan melalui pencatatan eksplisit setiap keputusan inklusi/eksklusi pada catatan sumber di *vault* Obsidian, namun triangulasi oleh lebih dari satu peninjau belum dapat dilakukan pada tahap ini.

3. Hasil dan Pembahasan

3.1 Perbedaan RaaS dan Ransomware Konvensional

Perbedaan paling mendasar antara RaaS dan ransomware konvensional terletak pada struktur kepemilikan alat serang dan pembagian risiko operasional. Pada ransomware konvensional, aktor yang mengembangkan *malware* adalah aktor yang sama yang mengeksekusi serangan dan menegosiasikan tebusan, sehingga pemodelan ekonomi klasik cenderung memperlakukan penyerang sebagai satu agen rasional tunggal yang membandingkan potensi keuntungan tebusan dengan biaya dan risiko penangkapan [3]. Laszka dkk. memformalkan keputusan korban untuk membayar sebagai fungsi perbandingan antara biaya tebusan (R) dan biaya pemulihan mandiri ditambah kerugian akibat gangguan operasional (C); korban rasional akan membayar apabila $R < C$ [3]. Formalisasi ini masih relevan sebagai fondasi teoretis, namun tidak lagi memadai untuk menjelaskan RaaS karena mengasumsikan penyerang sebagai agen tunggal, padahal RaaS justru memecah agen tunggal tersebut menjadi beberapa aktor dengan insentif berbeda.

Pada RaaS, hubungan antara pengembang dan pelaksana serangan diformalkan sebagai skema bagi hasil. Apabila total nilai tebusan yang terkumpul dinotasikan D , pendapatan afiliasi dapat dirumuskan sebagai $\alpha \times D$ dan pendapatan operator sebagai $(1-\alpha) \times D$, dengan α adalah rasio bagi hasil yang disepakati. Nilai α yang dilaporkan antarsumber, bagaimanapun, sangat bervariasi: Gray dkk. mendokumentasikan rasio afiliasi Conti berkisar 60–90% dari nilai tebusan [3], sementara Bhattacharai melaporkan kelompok LockBit generasi awal menerapkan rasio afiliasi yang jauh lebih rendah, sekitar 20–30% [8], dengan selisihnya dialokasikan untuk pengembangan kit, dukungan infrastruktur, dan komisi rekrutmen. Kontradiksi ini bukan sekadar perbedaan pencatatan, melainkan mengindikasikan bahwa rasio bagi hasil berfungsi sebagai instrumen kompetisi antaroperator RaaS untuk merebut afiliasi berkualitas tinggi di pasar kejahatan siber yang kompetitif [14], [15]— semakin ketat persaingan memperebutkan afiliasi terampil, semakin tinggi rasio yang cenderung ditawarkan operator.

Oosthoek dkk. menegaskan bahwa RaaS dan ransomware komoditas sesungguhnya beroperasi sebagai dua pasar yang berbeda struktur insentifnya: pasar komoditas menasar volume korban bernilai kecil dengan otomatisasi tinggi, sedangkan pasar RaaS bernilai besar menasar korban bernilai tinggi melalui afiliasi terlatih yang melakukan pergerakan lateral manual sebelum enkripsi [7]. Perbedaan struktural ini tercermin pula pada intensitas skema pemerasan; RaaS kontemporer umumnya menerapkan skema pemerasan berlapis (*double/triple/quadruple extortion*) yang menggabungkan enkripsi data, eksfiltrasi dan ancaman publikasi, serangan *distributed denial-of-service*, hingga tekanan langsung kepada pelanggan atau mitra korban [5], [4], sedangkan ransomware konvensional umumnya berhenti pada enkripsi tunggal. Ringkasan komparatif dimensi-dimensi tersebut, beserta seluruh sumber primer dan pendukung yang membentuk korpus penelitian, disajikan pada Tabel 1.

Tabel 1. Matriks Perbandingan Literatur (State-of-the-Art)

No	Penulis (Tahun)	Fokus Riset	Metode	Status	Temuan Kunci Relevan RQ
1	Laszka dkk. (2017) [3]	Ekonomi keputusan pembayaran tebusan	Pemodelan <i>game-theoretic</i>	Prosiding terindeks	Rumusan dasar R vs C; korban sebagai agen tunggal (RQ1)
2	Dhawan dkk. (2025) [1]	Ekonomi tebusan RaaS	Analisis data ekonomi	Preprint (non-peer-review)	Lonjakan nilai tebusan rata-rata 2019-2021 (RQ1)
3	Fachkha dkk. (2025) [20]	Evolusi historis RaaS (Babuk/GandCrab/Sodinokibi)	Studi historis-komparatif	Prosiding konferensi	Pola evolusi model bisnis antargenerasi (RQ1)
4	Gray dkk. (2022) [4]	Struktur bisnis Conti	Analisis kebocoran data internal	Prosiding terindeks	Rasio bagi hasil 60-90%; struktur mirip korporasi (RQ1, RQ2)
5	Oosthoek dkk. (2023) [7]	Struktur pasar RaaS vs komoditas	Analisis <i>on-chain</i> & studi kasus	Jurnal terindeks	Dua pasar terpisah dengan insentif berbeda (RQ1)
6	Cong dkk. (2025) [16]	Manajemen reputasi kejahatan siber kripto	Analisis <i>on-chain</i> kuantitatif	Jurnal terindeks	Reputasi aktif berkorelasi pendapatan lebih tinggi (RQ1, RQ3)
7	Phipps & Nurse (2025) [14]	Struktur organisasi Conti/LockBit/BlackCat	Analisis tematik kualitatif	Jurnal terindeks	Prosedur <i>vetting</i> afiliasi terstruktur terdokumentasi (RQ2, RQ3)
8	Meland dkk. (2020) [15]	Ekonomi RaaS di <i>darknet</i>	Studi pasar & forum	Jurnal terindeks	Sistem reputasi <i>vendor</i> menyerupai <i>e-commerce</i> (RQ3)
9	Décary-Hétu & Leppänen (2016) [11]	Kepercayaan kriminal di pasar <i>carding</i>	Analisis forum kriminal	Jurnal terindeks	Performa dinilai dari sinyal kepercayaan, bukan hanya skill (RQ3)
10	Dupont dkk. (2016) [12]	Ekologi kepercayaan komunitas peretas	Studi kualitatif komunitas	Jurnal terindeks	Reputasi & <i>vouching</i> menggantikan fungsi kontrak (RQ2, RQ3)
11	Milenkoski dkk. (2025) [9]	Nexus aktor negara & RaaS	Analisis kebijakan/intelijen	Laporan kelembagaan	Toleransi operasional bersyarat target luar negeri (RQ3)
12	Iwasaki (2025) [13]	Kebijakan larangan pembayaran tebusan	Analisis kebijakan-hukum	Jurnal terindeks	Efek tak diinginkan: turunnya pelaporan insiden (RQ3)
13	Bhattarai (2025) [8]	Forensik teknis LockBit	Analisis <i>malware</i> /forensik	Laporan riset independen	Rasio bagi hasil kontras, 20-30% (RQ1)
14	Qollakaj & Larsson (2023) [6]	Kerentanan VPN pascapandemi	Studi kerentanan/CVE	Tesis akademik	Vektor akses awal favorit <i>Initial Access Broker</i> (RQ2)

Sintesis dari ketiga temuan di atas menunjukkan bahwa RaaS pada dasarnya adalah reorganisasi rantai nilai kejahatan siber mengikuti logika *platform economy*: operator berperan sebagai penyedia infrastruktur-sebagai-layanan yang memonetisasi keahlian teknisnya melalui banyak pelaksana independen, alih-alih memonopoli seluruh rantai serangan seorang diri. Cong dkk. menunjukkan pola serupa berlaku lebih luas pada kejahatan siber berbasis kripto, di mana kelompok yang mengelola reputasi publiknya secara aktif — termasuk melalui layanan pelanggan bagi korban dan afiliasi — memperoleh pendapatan yang secara signifikan lebih tinggi dibandingkan kelompok yang tidak melakukannya [16]. Temuan ini memperkuat

argumen bahwa RaaS bukan sekadar inovasi teknis distribusi *malware*, melainkan inovasi organisasi yang meniru logika reputasi platform bisnis sah — argumen yang menjadi jembatan menuju pembahasan ekosistem aktor pada RQ2.

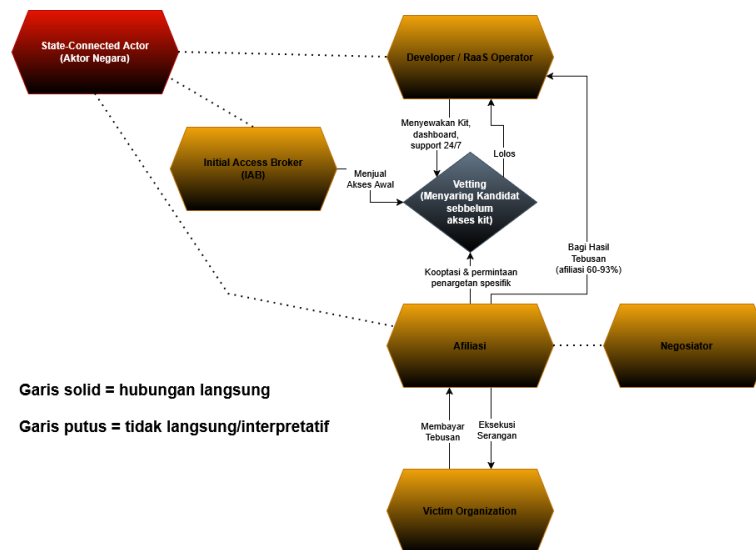
3.2 Komponen Ekosistem dan Interaksi Antaraktor

Ekosistem RaaS terdiri atas beberapa peran fungsional yang saling terhubung melalui rangkaian transaksi maupun pengaruh tidak langsung, sebagaimana diilustrasikan pada Gambar 2. Titik masuk rantai nilai umumnya berasal dari *Initial Access Broker* (IAB), aktor yang mengkhususkan diri memperoleh dan memperjualbelikan akses awal ke jaringan korban — antara lain melalui eksploitasi kerentanan infrastruktur VPN/*remote-access* yang meningkat pesat akibat migrasi kerja jarak jauh pascapandemi [6]. Qollakaj dan Larsson mendokumentasikan lonjakan signifikan kerentanan pada *gateway* VPN korporat pada periode 2020–2022, yang kemudian menjadi salah satu vektor akses awal favorit IAB [6].

Developer/operator RaaS menempati posisi sentral sebagai penyedia kit ransomware, dasbor manajemen kampanye, layanan negosiasi terenkripsi, dan dukungan teknis 24/7 kepada afiliasi yang telah lolos seleksi [14], [4]. Afiliasi kemudian menjalankan eksekusi teknis di lapangan — mulai dari pergerakan lateral, eskalasi privilege, hingga penyebaran *payload* — dan dalam banyak kasus turut berinteraksi dengan negosiator khusus yang menegosiasikan nilai tebusan akhir dengan korban [8]. Pembagian peran ini menciptakan spesialisasi tenaga kerja kriminal yang menyerupai struktur organisasi bisnis konvensional: Phipps dan Nurse menemukan bahwa kelompok seperti Conti bahkan mempekerjakan staf non-teknis dengan fungsi setara sumber daya manusia dan dukungan pelanggan, lengkap dengan struktur penggajian [14]. Laporan kriminologi dari Australian Institute of Criminology turut menunjukkan bahwa jalur karier pelaku RaaS individu kerap berpindah antarkelompok mengikuti reputasi dan rasio bagi hasil yang ditawarkan, memperkuat argumen bahwa loyalitas afiliasi bersifat transaksional dan reputasional, bukan institusional [21].

Dinamika interaksi antaraktor tidak selalu berjalan mulus. Kasus ransomware VECT yang diinvestigasi Check Point Research pada awal 2026 menunjukkan bahwa kegagalan mekanisme enkripsi akibat kesalahan implementasi kode justru mengubah ransomware tersebut menjadi *wiper* data yang tidak dapat dipulihkan — merusak kredibilitas afiliasi maupun operator yang mengoperasikannya dan berpotensi memutus rantai kepercayaan dengan afiliasi pada masa mendatang [10]. Sementara itu, kasus hukum terhadap seorang warga negara Latvia yang dijatuhi hukuman terkait perannya dalam skema ransomware bernilai jutaan dolar menggambarkan bahwa struktur ekosistem RaaS memungkinkan satu individu berperan lintas fungsi — pengembangan sekaligus operasional multi-merek — sebuah pola yang mempersulit atribusi hukum konvensional yang biasanya mengasumsikan struktur organisasi tunggal dan tetap [22].

Pola interaksi ini paling tepat dipahami melalui lensa ekologi kepercayaan (*ecology of trust*) yang dikembangkan Dupont dkk. dalam studi komunitas peretas: hubungan antaraktor kejahatan siber terorganisasi tidak dibangun di atas kontrak yang dapat ditegakkan secara hukum, melainkan atas reputasi, riwayat transaksi, dan jaringan rujukan (*vouching*) antaranggota [12]. Dalam konteks RaaS, logika ini termanifestasi pada bagaimana IAB, afiliasi, dan operator saling menyeleksi mitra transaksinya — sebuah tema yang kemudian mengarah langsung pada pembahasan mekanisme *vetting* pada RQ3.



Gambar 2. Peta konseptual interaksi antaraktor dalam ekosistem RaaS

3.3 Mekanisme Vetting sebagai Instrumen Tata Kelola

Vetting dalam konteks RaaS merujuk pada proses penyaringan kandidat afiliasi sebelum diberikan akses terhadap kit ransomware dan data korban potensial. Phipps dan Nurse mendokumentasikan bahwa kelompok seperti LockBit dan BlackCat/ALPHV menerapkan prosedur wawancara terstruktur, verifikasi riwayat operasi sebelumnya, serta dalam beberapa kasus meminta bukti kemampuan teknis (*proof-of-skill*) sebelum kandidat afiliasi memperoleh akses penuh [14]. Meland dkk. menambahkan bahwa pasar RaaS pada forum *darknet* turut mengadopsi sistem reputasi dan ulasan (*vendor rating*) yang mirip dengan pasar daring sah, di mana operator dengan riwayat pembayaran dan dukungan teknis yang konsisten memperoleh kepercayaan lebih tinggi dari calon afiliasi, dan sebaliknya afiliasi dengan riwayat transaksi baik lebih mudah diterima operator [15].

Kerangka teoretis dari kriminologi siber memperkuat interpretasi ini. Décary-Héту dan Leppänen menunjukkan bahwa performa kriminal di pasar *carding* bawah tanah dinilai bukan semata dari kemampuan teknis, melainkan dari konsistensi sinyal kepercayaan yang dibangun aktor dari waktu ke waktu — termasuk kepatuhan terhadap norma informal komunitas dan reputasi non-penipuan [11]. Diterapkan pada RaaS, temuan ini menunjukkan bahwa vetting afiliasi berfungsi ganda: sebagai uji kompetensi teknis sekaligus sebagai mekanisme mitigasi risiko reputasi dan risiko infiltrasi (misalnya oleh peneliti keamanan atau aparat penegak hukum yang menyamar). Artinya, operator RaaS menghadapi persoalan tata kelola yang secara struktural mirip dengan *principal-agent problem* dalam ekonomi organisasi konvensional: operator (*principal*) tidak dapat mengawasi tindakan afiliasi (*agent*) secara langsung, sehingga vetting menjadi instrumen penyaringan risiko *ex-ante* untuk mengurangi kemungkinan perilaku oportunistik atau kebocoran informasi setelah akses diberikan.

Namun demikian, ketatnya vetting tidak berlaku seragam di seluruh ekosistem RaaS. Sejumlah operator yang beroperasi pada segmen pasar bervolume tinggi cenderung melonggarkan kriteria seleksi demi memperbesar jaringan afiliasi secara cepat, dengan konsekuensi variasi kualitas eksekusi serangan yang lebih besar — sebagaimana tercermin dari insiden VECT yang gagal mengeksekusi fungsi enkripsi dengan benar [10]. Variasi ini menunjukkan adanya *trade-off* mendasar dalam tata kelola RaaS: seleksi ketat menjamin kualitas eksekusi dan reputasi jangka panjang tetapi membatasi skala operasi, sedangkan seleksi longgar memperbesar skala namun meningkatkan risiko kegagalan teknis dan paparan terhadap penegakan hukum. Trade-off inilah yang menjadi argumen inti bahwa vetting bukan sekadar prosedur administratif, melainkan pilihan strategis tata kelola yang memengaruhi keberlanjutan operasi kelompok RaaS secara keseluruhan.

Pada lapisan yang lebih tinggi, sejumlah bukti menunjukkan bahwa selektivitas RaaS tidak berhenti pada level afiliasi, melainkan meluas hingga ke kooptasi operator oleh kepentingan negara. Milenkoski dkk. mendokumentasikan pola di mana sejumlah operator RaaS yang beririsan secara geografis maupun personel dengan aktor yang terhubung negara memperoleh toleransi operasional dari otoritas domestiknya, sepanjang target serangan diarahkan ke luar yurisdiksi tersebut — sebuah bentuk *plausible deniability* yang menguntungkan kedua pihak [9]. Iwasaki menambahkan dimensi kebijakan yang relevan: kebijakan larangan pembayaran tebusan yang diberlakukan sejumlah yurisdiksi, alih-alih menekan aktivitas RaaS, berpotensi menimbulkan efek tidak diinginkan berupa penurunan pelaporan insiden oleh korban yang khawatir menghadapi sanksi hukum karena membayar tebusan secara diam-diam, sehingga justru mengurangi visibilitas otoritas terhadap skala sesungguhnya ekosistem RaaS [13].

3.4 Sintesis Vetting sebagai Tata Kelola Informal Tiga Pilar

Mengintegrasikan temuan RQ1–RQ3, penelitian ini mengusulkan bahwa vetting afiliasi merupakan simpul konseptual yang menyatukan dimensi ekonomi (bagi hasil dan struktur insentif pada RQ1), dimensi organisasi (interaksi antaraktor pada RQ2), dan dimensi keamanan-politik (nexus aktor negara). Berbeda dari tata kelola bisnis sah yang bertumpu pada kontrak yang dapat ditegakkan secara hukum, audit eksternal, dan reputasi merek publik, tata kelola RaaS bertumpu pada tiga pilar informal: (1) sinyal kepercayaan interpersonal dan riwayat transaksi [11], [12]; (2) sistem reputasi terdesentralisasi pada forum *darknet* yang berfungsi sebagai pengganti lembaga pemeringkat kredit [15]; dan (3) toleransi atau kooptasi oleh otoritas negara tertentu yang berfungsi sebagai pengganti perlindungan hukum formal [9]. Ketiga pilar ini saling menguatkan: semakin kuat sinyal kepercayaan dan reputasi yang dimiliki seorang afiliasi atau operator, semakin besar peluangnya lolos vetting, dan pada sejumlah kasus semakin besar pula toleransi implisit yang mungkin diperolehnya dari otoritas yang bersimpati atau berkepentingan geopolitik. Kerangka tiga pilar ini merupakan kontribusi orisinal penelitian yang belum dirumuskan secara eksplisit pada literatur yang direview, dan menjadi jawaban langsung atas RQ3 sekaligus simpul yang menyatukan Gambar 2 secara keseluruhan.

4. Kesimpulan

Penelitian ini menyimpulkan bahwa RaaS berbeda secara fundamental dari ransomware konvensional dalam hal struktur kepemilikan alat serang, distribusi risiko melalui skema bagi hasil yang kompetitif, serta intensitas skema pemerasan berlapis yang menjadikannya menyerupai dua pasar terpisah dengan logika insentif yang berbeda dari ransomware komoditas (RQ1). Ekosistem RaaS terbentuk dari spesialisasi peran fungsional — developer/operator, *Initial Access Broker*, afiliasi, dan negosiator — yang berinteraksi melalui rangkaian transaksi bernilai ekonomi sekaligus hubungan kepercayaan informal yang menyerupai ekologi kepercayaan pada komunitas peretas, bukan struktur organisasi formal dengan kontrak yang dapat ditegakkan secara hukum (RQ2).

Mekanisme *vetting* afiliasi terbukti berfungsi sebagai instrumen tata kelola informal yang mengintegrasikan tiga pilar: sinyal kepercayaan interpersonal, sistem reputasi terdesentralisasi ala pasar daring, dan pada level tertentu, toleransi implisit otoritas negara yang memiliki kepentingan geopolitik (RQ3). Temuan ini menunjukkan bahwa selektivitas afiliasi RaaS melampaui sekadar uji kemampuan teknis dan berfungsi sebagai pengganti fungsi tata kelola korporat maupun perlindungan hukum yang lazim terdapat pada entitas bisnis sah. Kontribusi konseptual utama penelitian ini adalah kerangka tiga pilar tata kelola informal tersebut, yang menjembatani literatur teknis-defensif dengan perspektif ekonomi-organisasi dan kriminologi siber yang selama ini berkembang secara terpisah.

Penelitian ini memiliki keterbatasan yang perlu menjadi perhatian pembaca dan arah penelitian lanjutan. Sifat tinjauan pustaka interpretatif membuat hasil kajian ini rentan terhadap bias seleksi dan belum melibatkan triangulasi oleh lebih dari satu peninjau; proporsi rujukan akademik terindeks pada Daftar Pustaka (sekitar 64%) juga belum sepenuhnya memenuhi ambang ideal 70% yang direkomendasikan standar akreditasi jurnal nasional, sekalipun telah dilakukan pencarian tambahan secara aktif untuk memperkuat komposisi tersebut. Penelitian lanjutan disarankan untuk memvalidasi kerangka tiga pilar tata kelola informal yang diusulkan melalui wawancara dengan praktisi *threat intelligence* atau analisis

kuantitatif tambahan atas data *on-chain* dan forum *darknet*, guna menguji generalisasi temuan pada varian RaaS yang belum tercakup dalam korpus penelitian ini.

Daftar Pustaka

- [1] A. Dhawan, S. Foley, and V. Mollica, "Splitting the Spoils: The Economics of Ransomware as a Service," *SSRN Electron. J.*.
- [2] J. Ferdous, R. Islam, A. Mahboubi, and M. Z. Islam, "AI-Based Ransomware Detection: A Comprehensive Review," *IEEE Access*, vol. 12, pp. 136666-136695, 2024, doi: 10.1109/ACCESS.2024.3461965.
- [3] A. Laszka, S. Farhang, and J. Grossklags, "On the Economics of Ransomware," in *Decision and Game Theory for Security (GameSec 2017), Lecture Notes in Computer Science*, vol. 10575, Springer, 2017, pp. 397-417, doi: 10.1007/978-3-319-68711-7_21.
- [4] I. W. Gray, J. Cable, B. Brown, V. Cuiujuclu, and D. McCoy, "Money Over Morals: A Business Analysis of Conti Ransomware," in *Proc. 2022 APWG Symposium on Electronic Crime Research (eCrime)*, IEEE, 2022, pp. 1-12, doi: 10.1109/eCrime57793.2022.10142119.
- [5] N. Masakapalli and R. Vodapally, "Ransomware as a Service (RaaS): Emerging Threats and Proactive Defense Tactics," *IRE J.*, vol. 8, no. 10, 2025.
- [6] K. Qollakaj and L. E. Larsson, "Cybersecurity of Remote Work Migration: A Study on the VPN Security Landscape Post COVID-19 Outbreak," Bachelor Thesis, Blekinge Institute of Technology, 2023.
- [7] K. Oosthoek, J. Cable, and G. Smaragdakis, "A Tale of Two Markets: Investigating the Ransomware Payments Economy," *Commun. ACM*, vol. 66, no. 8, pp. 74-83, 2023, doi: 10.1145/3582489.
- [8] K. Bhattarai, "Dissecting LockBit Ransomware: From Infection to Impact," *Indep. Res. Rep.*, 2025, doi: 10.13140/RG.2.2.13204.87687.
- [9] A. Milenkoski, J. Minier, J.-F. Vögele, M. Smeets, and T. Grossman, "Ransomware's New Masters: How States Are Hijacking Cybercrime," *Virtual Routes Pharos Ser.*, no. 3, 2025.
- [10] C. P. Research, "VECT: Ransomware by Design, Wiper by Accident," *Check Point Res. Blog Apr*, 2026.
- [11] D. Décary-Héту and A. Leppänen, "Criminals and Signals: An Assessment of Criminal Performance in the Carding Underworld," *Secur. J.*, vol. 29, no. 3, pp. 442-460, 2016, doi: 10.1057/sj.2013.19.
- [12] B. Dupont, A.-M. Côté, C. Savine, and D. Décary-Héту, "The Ecology of Trust Among Hackers," *Glob. Crime*, vol. 17, no. 2, pp. 129-151, 2016, doi: 10.1080/17440572.2016.1157480.
- [13] M. Iwasaki, "Banning Ransomware Payments: Unintended Effects on Cybersecurity Investment and Incident Reporting," *Int. Cybersecurity Law Rev.*, vol. 6, pp. 17-27, 2025, doi: 10.1365/s43439-025-00137-5.
- [14] A. Phipps and J. R. C. Nurse, "Inside Ransomware Groups: An Analysis of Their Origins, Structures, and Dynamics," *Comput. Secur.*, vol. 160, preprint 104705, 2025, doi: 10.1016/j.cose.2025.104705.
- [15] P. H. Meland, Y. F. F. Bayoumy, and G. Sindre, "The Ransomware-as-a-Service Economy Within the Darknet," *Comput. Secur.*, vol. 92, preprint 101762, 2020, doi: 10.1016/j.cose.2020.101762.
- [16] L. W. Cong, C. R. Harvey, D. Rabetti, and Z.-Y. Wu, "An Anatomy of Crypto-Enabled Cybercrimes," *Manag. Sci.*, vol. 71, no. 4, pp. 3622-3633, 2025, doi: 10.1287/mnsc.2023.03691.
- [17] M. Paquet-Clouston, B. Haslhofer, and B. Dupont, "Ransomware Payments in the Bitcoin Ecosystem," *J. Cybersecurity*, vol. 5, no. 1, preprint tyz003, 2019, doi: 10.1093/cybsec/tyz003.
- [18] V. Braun and V. Clarke, "Using Thematic Analysis in Psychology," *Qual. Res. Psychol.*, vol. 3, no. 2, pp. 77-101, 2006, doi: 10.1191/1478088706qp0630a.
- [19] D. Y. Huang, "Tracking Ransomware End-to-End," in *Proc. 2018 IEEE Symposium on Security and Privacy (SP)*, IEEE, 2018, pp. 618-631, doi: 10.1109/SP.2018.00047.
- [20] C. Fachkha, S. Razaulla, C. Markarian, A. Gawanmeh, B. C. M. Fung, and C. Assi, "Ransomware-as-a-Service and Its Evolution: Lessons from the Babuk, GandCrab, and Sodinokibi Families," *Conf. Pap.*, 2025.
- [21] A. I. Criminology, "Examining the Activities and Careers of Ransomware Criminal Groups," *Trends Issues Crime Crim. Justice*, no. 719, Sep. 2025.
- [22] S. Jain, "Latvian National Sentenced for Role in Multi-Million Dollar Ransomware Scheme," *Cyber Express*, May 2026.